

Company Security Policy — Page 1

1. Multi-Factor Authentication (MFA) is mandatory for all employee accounts.
2. Production databases must never be exported to unencrypted local devices.
3. Passwords must be at least 12 characters and rotated every 90 days.
4. Lost or stolen laptops must be reported to IT Security within 2 hours.
5. Customer PII must be masked in staging and development environments.
6. All company-issued devices must have full-disk encryption enabled before first use.
7. Employees must not use personal email accounts to transmit confidential company information.
8. Access to production systems requires a separate, named service account — shared credentials are prohibited.
9. Security incidents must be reported to the Security Operations Center (SOC) within 30 minutes of discovery.

Company Security Policy — Page 2

10. Remote access to internal systems must be established through the company-approved VPN only.
11. Public Wi-Fi networks must not be used to access company resources unless the VPN is active.
12. USB mass storage devices are prohibited on company endpoints unless explicitly approved by IT Security.
13. Third-party software installations on company devices require prior approval from the IT Asset Management team.
14. All software vulnerabilities rated 'Critical' or 'High' must be remediated within 14 calendar days of disclosure.
15. Employees must complete annual security awareness training within the first 30 days of employment and every 12 months thereafter.
16. Phishing simulations will be conducted quarterly; repeated failures will trigger additional mandatory training.
17. Email attachments from external senders must be treated as untrusted until verified with the sender through a secondary channel.
18. Confidential documents must be shared only through approved, access-controlled repositories — never via public file-sharing links.

Company Security Policy — Page 3

19. Cloud infrastructure changes must be peer-reviewed and deployed through the approved CI/CD pipeline.
20. Infrastructure-as-Code (IaC) templates must not contain hardcoded secrets; secrets must be stored in the company-approved secrets manager.
21. API keys, tokens, and service credentials must be rotated at least every 180 days.
22. Database backups must be encrypted at rest and stored in a geographically separate region.
23. Backup restoration tests must be performed at least once per quarter and documented.
24. Audit logs for privileged actions must be retained for a minimum of 12 months.
25. Access to audit logs must be restricted to authorized Security and Compliance personnel only.
26. Terminated employees must have all system access revoked within 4 hours of the effective termination time.
27. Role changes within the company must trigger a review of all associated system permissions within 5 business days.

Company Security Policy — Page 4

28. Data classified as 'Confidential' or 'Restricted' must not leave company-controlled environments without written approval from the Data Protection Officer.
29. Cross-border data transfers must comply with applicable data protection regulations (e.g., GDPR, DPDP Act).
30. Data subject access requests (DSARs) must be acknowledged within 72 hours and fulfilled within the regulatory deadline.
31. Personal data must be deleted upon expiration of its documented retention period, unless a legal hold applies.
32. Employees must report suspected data leaks — including accidental email misdelivery — to the Data Protection Officer within 1 hour.
33. Business continuity and disaster recovery plans must be tested at least annually.
34. Vendor and third-party security assessments must be completed before onboarding any system that processes company data.
35. Non-compliance with any policy in this document may result in disciplinary action, up to and including termination of employment and legal action.
36. This policy is reviewed annually by the Information Security team and is subject to change with 30 days' written notice.